〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.21(수)

■ 활동 날짜 및 참여 조원

· 날짜: 2026-10-21(수), 개별 작업 + Notion 작업 보고서 공유

· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

■ 오늘의 목표

· 통합 점검 1차(Graylog→n8n) 진행 및 AI 모델·네트워크 구성 변경을 기획서·계획서에 반영

· 외부 PC에서 실제로 공격을 재현할 수 있는 경로 완성, 실제 IP가 보존되는 구조로 전환

· R1·R2를 포함한 AI 무관 규칙(R1, R5~R10)을 Graylog에서 n8n까지 실제로 연결

■ 조원별 활동 내역

▶ 진혜정 (자동화·n8n·상황판)

· 포털 AI 어시스턴트가 이미 4가지 모델(자동 선택: Groq→로컬 Ollama→내장) 중 선택하는 화면으로 구현돼 있는 것을 확인, 기획서·계획서의 AI 설명을 "Groq 사용"에서 "자동 선택(4종)"으로 정정

· 구성 변경(AI는 Groq 무료 API, 장비 배치: pfSense=이시헌·Graylog2·n8n=김태빈·포털=홍주형·공격=진혜정)을 반영해 기획서·계획서 전면 수정 — R5~R12 표·자동 대응 표·구현 완료 현황·검증 계획·위험 표 보강, 망 구성도 이름표 교체, 두 문서 PDF 재발행

· 홍주형·이시헌과 함께 포털 연결 문제(직접 접속 차단 후 pfSense 경유 접속도 같이 끊기던 현상) 디버깅 — 원인은 HAProxy가 백엔드로 요청을 못 넘겨 타임아웃이었고, 이시헌이 백엔드 설정을 바로잡아 해결(경유 접속 HTTP 200 확인)

· 오후에 강사님·홍주형이 건 IP 차단을 공격 관점에서 우회하는 시험 진행 — 헤더 스푸핑(X-Forwarded-For 등 6종)은 전부 실패(양호한 방어), 짧은 TTL 차단은 대기 후 재시도로 한 번 뚫림(보완 후보로 기록), MAC 변경 시도는 macOS Wi-Fi 하드웨어 제한으로 실패, 이후 학원 와이파이 장애로 중단

▶ 홍주형 (웹·DB 하드닝)

· Wazuh Agent를 nexus-board-14로 분리해 15번 관제 PC에 정상 등록(Active/Online), 실시간 FIM 가동 확인

· 포털 웹(5070)은 pfSense 경유만, DB(3307)는 15번 PC만 허용하는 방화벽 규칙 적용, 실시간 공격 IP 자동 차단(blocked_ips, n8n 자동화+관리자 수동 차단 UI) 구축

· 15번 PC 관제 스택 분리 — 14번 PC에서 Wazuh Manager·Graylog·OpenSearch 컨테이너를 퇴역시키고 메인 DB만 경량 상주하도록 정리

· SOC 대시보드 전면 개편(DEFCON 위협 상황판, 4대 파이프라인 노드, 위협 탐지 레이더, 원클릭 IP 격리), IP 수동 차단 500 에러(log_event 인자 중복, security 모듈 미임포트) 긴급 수정

· IAM 사용자 관리 디렉토리 개편(5대 KPI 카드, 검색·필터), 역할 체계를 3단계에서 6단계(admin/sec_admin/hr_admin/finance_admin/manager/employee)로 확장, hongjh 계정을 최고관리자로 고정

· 인사카드 수정 기능 신설(권한자 전용, PoLP 기반 DB 권한 부여), 결재선을 전 직원에게 개방(자가결재

방지는 유지) — 관련 테스트 5개 스위트(test_security 17, test_blocked_ips 20, test_hr 49, test_admin 28, test_approval_ops 66) 전부 PASS

▶ 이시헌 (네트워크)

· 표 6(네트워크 역할 B) 5개 작업 전부 완료, Kali 5단계 공격 재현 전체 성공(FLAG 획득)까지 마무리

· 외부 PC→이 PC→pfSense WAN→포털 3단 경로 신규 구축(VMware NAT 포트포워딩 + HAProxy + 아웃바운드 SNAT), 다른 물리 PC에서 curl로 200 확인, 로그인 실패 5회 반복 시 Graylog 경보·Discord 알림 정상 도착까지 검증

· pfSense에 HAProxy 도입해 X-Forwarded-For로 실제 공격자 IP를 포털 로그(src_ip)까지 복원(기존 순수 NAT은 L4라 전부 pfSense IP로만 찍히던 문제 해결), 포털 쪽 신뢰 프록시 목록 반영과 맞춰 admin/audit에서 실제 IP 확인

· Discord 알림 포맷 개선과 중복 경보 규칙(신규 NEXUS T1~W1 9개) 정리 — 10/20 작업과 같은 방향으로 재확인

· 당일 이슈: VMnet8 어댑터 IP 유실(갱신으로 해결), WAN→포털 아웃바운드 SNAT 누락(전용 규칙 추가로 해결), SSH 키 캐시 불일치, HAProxy 전환 시 기존 WAN 허용 규칙 유실(전용 규칙 추가), 로그인 실패 스크립트의 밑줄(_) 복사 누락 버그(의존 줄여 재작성)

▶ 김태빈 (탐지)

· .14 게시판 서버·.15 관제 서버 간 Graylog GELF 수신, Wazuh Agent 연결, MySQL 3307 접근을 확인 — 앱 보안 이벤트는 Graylog, Windows 로그인·파일 변경 등 시스템 이벤트는 Wazuh가 담당하도록 로그 역할 정리

· Graylog의 R1, R5~R10을 n8n Notification에 연결(민감 정보·원문 제외, 실제 Event 필드만 전달), 기존 R2 연결 유지, n8n의 R5~R10 분기 호환성 수정(R6은 request_id 요구 제거하고 lock_request_id·alert.id 기준으로 변경)

· 검증 동안 response_mode=dry-run, live_enabled=false 유지 — R2 1회 검증에서만 discord_enabled=true로 바꿔 Publish, DB 대응·pfSense 차단은 실행하지 않음

· R2/R5/R6/R9/R10 E2E 흐름 확인, R1은 수정 후 Graylog→n8n→Ticket 생성까지 성공(NX-0008), R8 404 탐지·Ticket 생성·중복 방지 확인 — 기존 alert.id 재전달은 전부 중복 처리되어 Ticket 수·last_seen이 불필요하게 늘지 않는 것까지 확인

· R2 Discord 최종 검증은 GELF로 안전한 테스트 로그 1건을 보내 실제 Graylog Event를 생성하는 방식으로 수행 — Graylog Event 01M5ER4K0ZGNAZBWV15BG82FZ6 → n8n execution 399 → Ticket NX-0009로 연결, Discord 노드 success=true 확인(n8n Webhook에 synthetic payload 직접 전송은 아님, Graylog 이후 경로만 확인한 것)

· R7은 KST 00~05시 조건이라 실검증하지 못함, R3/R4/R11/R12는 아직 미구현 상태로 확인

· R1 Notification에서 빈 필드 포함 시 422가 발생하던 문제를 값 없는 필드 제외 + severity/action_level 계약 정정으로 해결, R8은 path를 집계 기준에 넣으면 탐지 의미가 달라져 기존 src_ip 집계를 유지(path 없을 때 fallback 처리)

· 진단 응답에 Graylog Notification 인증 헤더 값이 노출된 사실을 확인 — 비밀값은 기록하지 않았으며 Graylog·n8n 양쪽의 토큰 교체가 남은 작업으로 확인됨

■ 조원별 의견 및 제안 사항

· 진혜정: 애플리케이션 레벨 IP 차단이 클라이언트가 보내는 어떤 헤더도 신뢰하지 않는 구조라 헤더 스푸핑에는 안전했지만, 짧은 차단 TTL은 대기 후 재시도로 뚫릴 수 있다는 점을 팀에 공유할 가치가 있다고 판단

· 이시헌: 순수 NAT(L4)만으로는 실제 공격자 IP를 복원할 수 없고, 프록시 계층(HAProxy)에서 X-Forwarded-For를 명시적으로 다뤄야 탐지·대응이 출발지 기준으로 의미를 가진다는 걸 재확인

· 김태빈: 중복 alert.id 재전달이 전부 걸러지는 것을 확인한 게, 추후 재시도·재전송이 많아질 공방전 환경에서 티켓 수 폭증을 막는 근거가 될 것

■ 회의 결과 및 결정 사항

1. 외부 PC→pfSense→포털 3단 경로와 HAProxy 기반 실제 IP 복원 구조를 표준 경로로 확정
2. R1·R2·R5~R10의 Graylog→n8n 연결을 1차로 완료, R3/R4/R11/R12는 추후 AI 연동 이후 구현하기로 함
3. Discord 알림은 축약 포맷으로 통일하고 중복 경보 규칙(신규 9개)은 계속 비활성 유지
4. Graylog Notification 인증 헤더 교체는 다음 작업으로 이월

■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황

- 외부 PC 공격 재현 경로와 실제 IP 복원 구조가 완성돼 공방전 시연 기반이 마련됨
- R1·R2·R5~R10 E2E(Graylog→n8n→Ticket→Discord)가 실제 이벤트 기준으로 확인됨
- 포털 쪽 IAM·대시보드·결재 기능이 큰 폭으로 고도화되고 테스트 전부 통과

· 어려운 점

1. R7(심야 로그인)은 시간대 제약으로 실검증 불가, R3/R4/R11/R12는 AI 연동 전이라 미구현 상태
2. 짧은 차단 TTL 재시도 우회, 진단 응답의 인증 헤더 노출 등 보완이 필요한 지점이 새로 발견됨
3. HAProxy 전환·SNAT 규칙 등 네트워크 쪽 구성 변경이 많아 당일 트러블슈팅 비중이 컸음

■ 향후 활동 계획 및 역할 분담

· 유선 연결·다른 PC로 IP 우회 시험 이어가기(진혜정)

· Groq API 키 설정 여부 포털 화면에서 직접 확인(진혜정)

· Graylog·n8n 양쪽 Notification 인증 토큰 교체(김태빈)

· R3/R4/R11/R12는 AI 에이전트 연동 이후 순차 구현(전체)

· 엑셀(방어전_팀_역할.xlsx)·일정 자료를 이번 변경 기준으로 정리(진혜정)

■ 증거 자료

· 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/21) 페이지

- 진혜정 - 10/21 작업 / 2026-10-21 NEXUS WORK 작업 회고록(홍주형) / 10/21일 작업 현황 보고서(이시헌) / 2026-10-21 작업 기록(김태빈, 개인 워크스페이스)